

Zero Trust QA Coverage Gap Analysis

As part of this exercise, I reviewed the testing activities completed in Labs 0.1, III.2, III.4, III.5, and III.8 and compared them with the seven Zero Trust principles defined in NIST SP 800-207. The purpose was to understand which Zero Trust requirements are already being validated and identify areas where additional testing may be needed.

From the review, I found that authentication and authorization are covered quite well. The MFA login test cases, API testing, Playwright automation, and security assessment all verify that only authenticated users can access resources. Secure communication is also addressed through the network traffic analysis performed in Lab 0.1, where HTTPS communication and login traffic were examined. In addition, API and portal testing demonstrate that enterprise applications and services are treated as protected resources.

However, some areas are not covered as thoroughly. While login and logout functionality are tested, there are no specific test cases for session timeout or automatic session termination after inactivity. Policy assignment is validated, but there is no testing to confirm whether access permissions change immediately when a policy is modified. Device enrolment is also tested, but there is no scenario that checks how the system reacts when an enrolled device becomes non-compliant or fails security checks.

Another area that could be improved is audit logging. Although security testing identifies vulnerabilities, there is no direct verification that important security events such as logins, failed login attempts, or policy changes are properly recorded in audit logs.

Among all the gaps identified, device posture validation appears to be the most important. Zero Trust relies on continuously verifying both the user and the device. Adding tests for non-compliant devices, session expiration, policy updates, and audit log verification would provide better coverage and improve confidence in the overall Zero Trust implementation.